

Data, Privacy & Security Policy

****Document Number:**** 06

****Version:**** 1.0

****Effective Date:**** [DATE]

****Last Reviewed:**** [DATE]

****Approved By:**** [BOARD/EXECUTIVE BODY]

1. Purpose and Scope

1.1 Purpose

This Data, Privacy & Security Policy establishes comprehensive standards for the collection, processing, storage, and protection of data by [ORGANIZATION NAME] ("Organization"). This policy reflects our commitment to respecting individual privacy, maintaining data security, and complying with applicable privacy regulations including GDPR, CCPA, and other relevant frameworks.

1.2 Scope

This policy applies to:

- ****All Personnel:**** Board members, officers, employees, volunteers, contractors, and agents
- ****All Data:**** Personal data, organizational data, and third-party data in our custody
- ****All Systems:**** Information technology systems, cloud services, and third-party processors
- ****All Activities:**** Data collection, processing, storage, transmission, and destruction
- ****All Locations:**** Physical offices, remote work, cloud environments, and partner systems

1.3 Policy Principles

1. ****Data Minimization:**** Collect only what is necessary
2. ****Purpose Limitation:**** Use data only for stated purposes
3. ****Privacy by Design:**** Build privacy into systems and processes
4. ****Security First:**** Protect data with appropriate safeguards
5. ****Transparency:**** Be clear about data practices
6. ****Individual Rights:**** Respect and enable data subject rights

2. Data Collection Principles

2.1 Lawful Basis for Processing

All data collection must have a lawful basis under applicable privacy law:

Basis	Use Case	Documentation Required
-----	-----	-----
Consent	Marketing, optional communications	Clear opt-in, granular, revocable
Contract	Service delivery, membership	Contract terms reference
Legal Obligation	Tax reporting, regulatory compliance	Legal citation
Vital Interests	Emergency contact, health/safety	Incident documentation
Public Interest	Research in public benefit	Research ethics approval
Legitimate Interests	Internal analytics, fraud prevention	Legitimate Interest Assessment

2.2 Data Minimization

****Principle:**** Collect only data that is directly necessary for the specific purpose identified.

****Requirements:****

- Document the specific purpose for each data element collected
- Review collections annually for continued necessity
- Delete data when purpose is fulfilled (unless retention required)
- Do not collect "nice to have" data without explicit justification

****Examples:****

Purpose	Required Data	Not Required
-----	-----	-----
Email newsletter	Email address	Phone, address, demographics
Event registration	Name, email, dietary restrictions	SSN, full address (unless shipping)
Donation processing	Payment info, name, tax ID (for receipts)	Employer, occupation (unless legally required)
Research participation	Consent, relevant responses	Identifying info (use pseudonymization)

2.3 Purpose Limitation

****Principle:**** Use data only for the purpose for which it was collected, unless compatible additional purpose or new consent obtained.

****Compatible Purposes (generally permitted):****

- Archiving in public interest
- Scientific or historical research
- Statistical analysis (anonymized)
- Internal operational improvements

****Incompatible Purposes (require new basis):****

- Marketing to non-consented individuals
- Selling or sharing with third parties
- Uses materially different from original purpose
- New data controller relationship

2.4 Collection Methods

****Direct Collection:****

- Web forms with clear privacy notices
- In-person with informed consent
- Phone with verbal privacy notice

****Automated Collection:****

- Website analytics (cookie consent required)
- System logs (anonymized where possible)
- Public sources (disclosed in privacy notice)

****Third-Party Collection:****

- Processor agreements required
- Verify third-party compliance
- Disclose source in privacy notice

3. Privacy Commitments

3.1 Core Privacy Pledge

The Organization commits to:

****We Will NOT:****

- Sell personal data to third parties
- Share data with third parties for their marketing
- Use data for purposes beyond those disclosed
- Retain data longer than necessary
- Collect data from children under 13 without parental consent
- Discriminate against individuals exercising privacy rights

****We Will:****

- Be transparent about data practices
- Provide meaningful privacy choices
- Protect data with appropriate security

- Honor data subject rights promptly
- Notify of breaches as required by law
- Regularly review and improve privacy practices

3.2 Privacy Notice Requirements

All collection points must include a privacy notice containing:

1. **Identity:** Who is collecting the data
2. **Contact:** Data protection officer contact
3. **Purpose:** Why data is being collected
4. **Legal Basis:** Lawful basis for processing
5. **Recipients:** Who data will be shared with
6. **Transfers:** International transfer safeguards
7. **Retention:** How long data will be kept
8. **Rights:** Data subject rights and how to exercise
9. **Complaints:** How to lodge complaints with authorities
10. **Automated Decisions:** Existence of profiling (if any)

3.3 Special Categories of Data

The following "special category" data receives enhanced protection:

Category	Examples	Requirements
Racial/Ethnic Origin	Race, ethnicity	Explicit consent or substantial public interest
Political Opinions	Party affiliation, voting	Explicit consent or substantial public interest
Religious Beliefs	Religion, denomination	Explicit consent or substantial public interest
Health Data	Medical conditions, disabilities	Explicit consent or health/social care purpose
Biometric	Fingerprints, facial recognition	Explicit consent, Data Protection Impact Assessment
Genetic	DNA, genetic markers	Explicit consent, DPIA, specialized security
Sexual Orientation	LGBTQ+ status	Explicit consent
Criminal History	Convictions, offenses	Official authority or substantial public interest

Collection of special category data requires:

- Data Protection Impact Assessment (DPIA)
- Enhanced security measures
- Explicit opt-in consent (if consent basis)
- Documentation of lawful basis
- Limited access and strict need-to-know

3.4 Children's Data

****COPPA/GDPR Requirements:****

- No collection from children under 13 without verifiable parental consent
- For 13-16: Informational notice sufficient (opt-out)
- Clear age gating on websites and services
- No behavioral advertising to children
- Enhanced security for children's data

****Verifiable Consent Methods:****

- Credit card verification
- Signed consent form
- Video conference with parent
- Phone call with trained staff

4. Data Subject Rights

4.1 Rights Overview

Data subjects have the following rights:

Right	Description	Response Time
-----	-----	-----
Access	Obtain copy of personal data	30 days
Rectification	Correct inaccurate data	30 days
Erasure	Delete data ("right to be forgotten")	30 days
Restriction	Limit processing	30 days
Portability	Receive data in machine-readable format	30 days
Objection	Object to processing	Immediate effect
Automated Decision	Human review of automated decisions	30 days

4.2 Request Handling Procedures

****Receipt:****

- Acknowledge request within 72 hours
- Verify identity of requestor
- Log request in tracking system

****Processing:****

- Gather relevant data across systems
- Review for legal exemptions (e.g., legal obligation to retain)
- Prepare response in accessible format

- Quality assurance review

****Response:****

- Provide data or explanation of action taken
- Explain any exemptions applied
- Include information on appeal process
- Document completion

****Extensions:****

- Complex requests: May extend to 60 days with notification
- High volume: May extend with notification
- Must explain basis for extension

4.3 Exemptions and Limitations

****Requests May Be Denied When:****

Situation	Rationale
Legal obligation to retain	Tax, employment law requirements
Legal proceedings	Litigation hold or defense
Public interest	Research, public health, journalism
Manifestly unfounded	Harassment, excessive requests
Excessive requests	Repetitive, unreasonable burden
Others' rights	Would disclose another person's data

****Partial Response:****

When portions must be withheld, provide:

- Redacted version with explanation
- Basis for withholding (legal citation)
- Appeal rights

5. Security Baseline

5.1 Security Governance

****Security Officer:** [NAME/TITLE]**

****Responsibilities:****

- Security policy development and enforcement
- Risk assessment and management
- Incident response coordination
- Security awareness training

- Vendor security evaluation

****Security Committee:****

- Cross-functional representation (IT, Legal, Operations)
- Monthly security reviews
- Incident post-mortems
- Policy approval authority

5.2 Access Controls

****Principle of Least Privilege:****

- Access granted on need-to-know basis
- Role-based access control (RBAC)
- Regular access reviews (quarterly)
- Immediate revocation upon termination

****Authentication Requirements:****

System Type	Minimum Requirement
-----	-----
Standard systems	Strong password + MFA
Administrative systems	Strong password + hardware MFA
Critical infrastructure	Certificate-based + MFA
External access	VPN + MFA

****Password Policy:****

- Minimum 12 characters
- Complexity required (upper, lower, number, special)
- No dictionary words or personal info
- Changed immediately if suspected compromise
- Password manager required

5.3 Encryption Standards

****Data at Rest:****

- Full disk encryption on all devices
- Database encryption (AES-256)
- Encrypted backups
- Secure key management (HSM or KMS)

****Data in Transit:****

- TLS 1.3 minimum for web traffic
- VPN for remote access
- SFTP/FTPS for file transfers

- Encrypted email for sensitive data

****Key Management:****

- Keys stored in hardware security module or cloud KMS
- Key rotation annually or on compromise
- Separation of duties for key access
- Key escrow for business continuity

5.4 Network Security

****Perimeter Protection:****

- Next-generation firewall with IDS/IPS
- DDoS protection
- Web application firewall (WAF)
- Regular penetration testing (annual)

****Network Segmentation:****

- VLAN separation by function
- Critical systems isolated
- Guest network separate from production
- Zero-trust architecture for remote access

****Monitoring:****

- 24/7 security monitoring
- SIEM for log aggregation and analysis
- Anomaly detection
- Threat intelligence feeds

5.5 Endpoint Security

****Device Requirements:****

- Organization-approved devices for work data
- MDM enrollment for all mobile devices
- EDR (Endpoint Detection and Response) on all endpoints
- Automatic updates and patching

****Prohibited:****

- Personal email for work data
- Unapproved cloud storage
- Unencrypted removable media
- Jailbroken/rooted devices

****Remote Work:****

- VPN required for system access

- Home network security recommendations
- Dedicated workspace guidance
- No work in public spaces with visible screens

5.6 Application Security

Development:

- Secure coding standards
- Code review requirements
- Dependency vulnerability scanning
- Static and dynamic security testing (SAST/DAST)

Production:

- Regular vulnerability scanning
- Patch management (critical: 24 hours, high: 7 days)
- Change management process
- Segregated production access

Third-Party:

- Security assessment before procurement
- Annual security review
- Right to audit clauses
- Incident notification requirements

5.7 Physical Security

Office Security:

- Badge access control
- Visitor escort required
- Clean desk policy
- Secure disposal (shredding)

Data Center / Server Room:

- Multi-factor physical access
- Environmental controls
- CCTV monitoring
- Fire suppression systems

Remote Work:

- Secure home office setup
- Privacy screens for laptops
- Safe storage of devices
- No unattended devices in public

6. Incident Response

6.1 Incident Classification

Severity	Definition	Examples	Response Time
-----	-----	-----	-----
Critical	Active breach, massive data exposure Ransomware, major unauthorized access		
Immediate			
High	Confirmed breach, significant data Unauthorized admin access, customer data exposure 1 hour		
Medium	Potential breach, limited data Phishing success, misdirected email 4 hours		
Low	Attempted attack, no breach Failed intrusion attempts, spam 24 hours		

6.2 Incident Response Team

****Core Team:****

- Security Officer (Incident Commander)
- IT/Systems Administrator
- Legal Counsel
- Communications Lead
- Executive Sponsor

****Extended Team (as needed):****

- HR (personnel incidents)
- External forensics
- Law enforcement liaison
- Insurance carrier
- Affected system owners

6.3 Response Procedures

****Phase 1: Detection and Analysis (0-1 hour)****

1. Identify and confirm incident
2. Assign severity classification
3. Activate response team
4. Preserve evidence
5. Document timeline

****Phase 2: Containment (1-4 hours)****

1. Isolate affected systems
2. Block attack vectors
3. Prevent data exfiltration

4. Maintain business continuity where safe

****Phase 3: Eradication (4-24 hours)****

1. Remove attacker access
2. Patch vulnerabilities
3. Clean compromised systems
4. Verify integrity

****Phase 4: Recovery (24-72 hours)****

1. Restore from clean backups
2. Verify system integrity
3. Return to normal operations
4. Enhanced monitoring

****Phase 5: Post-Incident (1-4 weeks)****

1. Complete forensic analysis
2. Document lessons learned
3. Update security controls
4. Conduct post-mortem

6.4 Breach Notification

****Legal Notification Requirements:****

| Jurisdiction | Trigger | Timeline | Recipients |

|-----|-----|-----|-----|

| ****GDPR**** | Likely result in risk to rights | 72 hours to DPA | Supervisory authority; data subjects if high risk |

| ****CCPA**** | Unauthorized access | Without unreasonable delay | California Attorney General; consumers if >500 affected |

| ****Other States**** | Varies | Varies (typically 30-60 days) | Attorney General; affected individuals |

****Internal Notification:****

- Board Chair: Within 4 hours for Critical/High
- Full Board: Within 24 hours
- Insurance carrier: Within policy timeframe

****External Communication:****

- Draft by Legal and Communications
- Board approval required
- Transparent but legally protective
- Offer credit monitoring if SSN/financial involved

6.5 Documentation Requirements

Maintain for duration of litigation plus 7 years:

- Incident timeline
- All communications
- Forensic analysis
- Response actions taken
- Notification records
- Post-incident report
- Lessons learned

7. Third-Party Processors

7.1 Due Diligence

****Before Engagement:****

- Security questionnaire
- SOC 2 Type II or equivalent review
- Data Processing Agreement (DPA) execution
- Privacy Shield or SCCs for international transfers

****Minimum Security Requirements:****

- Encryption at rest and in transit
- Access controls and MFA
- Incident response capabilities
- Annual penetration testing
- Business continuity plan

7.2 Data Processing Agreements

All processors must sign DPA containing:

- Processing instructions and limitations
- Subprocessor authorization and notification
- Security measures and audits
- Breach notification (24-48 hours)
- Data subject rights assistance
- Return/destruction of data upon termination
- Audit rights

7.3 Ongoing Monitoring

****Annual Review:****

- Security certification renewal
- Incident history review
- Compliance attestation
- Contract compliance verification

****Continuous Monitoring:****

- Threat intelligence on processors
- News and breach monitoring
- Performance and availability

8. International Data Transfers

8.1 Transfer Mechanisms

****From EU/EEA:****

- Standard Contractual Clauses (SCCs) - mandatory
- Adequacy decisions (UK, limited others)
- Binding Corporate Rules (if applicable)

****From UK:****

- UK Addendum to SCCs
- UK adequacy regulations

****From Other Jurisdictions:****

- Local law compliance
- Contractual safeguards
- Data localization requirements

8.2 Transfer Impact Assessment (TIA)

Required before international transfers:

1. Document laws in destination country
2. Assess impact on data subject rights
3. Identify supplementary measures if needed
4. Implement additional safeguards
5. Periodic re-assessment

8.3 Supplementary Measures

When destination laws may impede data subject rights:

- Enhanced encryption (data encrypted with keys held in origin country)
- Pseudonymization before transfer
- Strict purpose limitation
- Enhanced monitoring

9. Compliance and Governance

9.1 Privacy by Design

All new projects and systems must undergo:

****Privacy Impact Assessment (PIA) for:****

- New data collections
- New processing activities
- Significant system changes
- New vendor relationships

****Data Protection Impact Assessment (DPIA) for:****

- Systematic monitoring
- Large-scale special category processing
- Automated decision-making with significant effects
- New technologies (AI, biometrics)

9.2 Training and Awareness

| Audience | Training | Frequency |

|-----|-----|-----|

| All Staff | General security and privacy awareness | Annually |

| Developers | Secure coding, privacy engineering | Annually |

| Managers | Data handling, incident reporting | Annually |

| New Hires | Security and privacy basics | Within 30 days |

| High-Risk Roles | Specialized training | Semi-annually |

9.3 Audits and Assessments

****Annual Activities:****

- Security risk assessment
- Privacy compliance audit
- Penetration testing
- Vulnerability scanning

- Third-party security reviews

****Quarterly Activities:****

- Access reviews
- Policy compliance spot checks
- Incident metrics review
- Security metrics review

9.4 Record Keeping

Maintain for compliance:

- Processing activities records (ROPA)
- Consent records
- Data subject request logs
- DPIAs and PIAs
- Security assessments
- Incident reports
- Training records
- Processor agreements

Retention: Duration of processing plus [NUMBER] years

10. Implementation Notes

10.1 Immediate Actions (0-30 Days)

- [] Appoint Data Protection Officer / Privacy Officer
- [] Inventory all data processing activities (ROPA)
- [] Map all data flows and international transfers
- [] Review and update privacy notices
- [] Implement consent management platform
- [] Establish data subject request intake process

10.2 Short-Term Actions (30-90 Days)

- [] Complete DPIAs for high-risk processing
- [] Audit third-party processors for DPA compliance
- [] Deploy data subject rights request management system
- [] Conduct security risk assessment
- [] Implement security monitoring and alerting
- [] Develop incident response playbooks

10.3 Ongoing Actions

- [] Monthly security metrics review
- [] Quarterly access reviews
- [] Quarterly privacy compliance checks
- [] Annual penetration testing
- [] Annual policy and training refresh
- [] Annual ROPA update
- [] Continuous consent and preference management

10.4 Key Contacts

Role	Name/Email	Responsibilities
Data Protection Officer	[EMAIL]	GDPR compliance, data subject rights
Security Officer	[EMAIL]	Security program, incident response
Privacy Counsel	[EMAIL]	Legal compliance, regulatory matters
IT Security Lead	[EMAIL]	Technical security implementation

11. Regulatory Compliance Summary

11.1 GDPR (General Data Protection Regulation)

****Applicability:**** Processing personal data of EU residents

****Key Requirements:****

- Lawful basis for processing
- Data subject rights
- Privacy by design
- Breach notification (72 hours)
- DPO (if required by scale/sensitivity)
- Records of processing activities

11.2 CCPA/CPRA (California)

****Applicability:**** For-profit or non-profit with >\$25M revenue or >100K CA residents' data

****Key Requirements:****

- Privacy notice at collection
- Right to know, delete, opt-out
- Do not sell/share (opt-out link)
- Service provider contracts
- Consumer request fulfillment

11.3 Other State Laws

Monitor compliance requirements for:

- Virginia CDPA
- Colorado CPA
- Connecticut CTDPA
- Utah UCPA
- Emerging state privacy laws

11.4 Industry-Specific

****If Applicable:****

- HIPAA (health information)
- FERPA (educational records)
- GLBA (financial information)
- COPPA (children's online privacy)

Document Control

Version	Date	Author	Changes
-----	-----	-----	-----
1.0	[DATE]	[AUTHOR]	Initial policy

****Acknowledgment****

I have received, read, and understood the Data, Privacy & Security Policy. I agree to comply with its requirements and understand that violations may result in disciplinary action.

Employee Name: _____

Signature: _____

Date: _____